Disciplina: Segurança da Informação
Prof.: Gilmar Gomes do Nascimento

Nome: _____

INSTITUTO FEDERAL
Tocantins

---

1. Descreva o conceito de SSRF (Server-Side Request Forgery).

2. Diferenças entre SSRF in-band e cego

3. Escreva V ou F para cada assertiva sobre vulnerabilidades em SSRF:

( ) O navegador do usuário é enganado
( ) O servidor é quem faz a requisição
( ) O alvo típico é a rede interna, localhost e APIs
( ) O SSRF é menos perigoso, pois as requisições se originam de um servidor confiável
( ) O alvo canônico para ataques de SSRF em ambientes de nuvem é: `/latest/meta-data/iam/security-credentials/`
( ) Se acessível via SSRF, pode revelar credenciais temporárias (IAM roles) que permitem controle total sobre a infraestrutura
( ) APIs que consomem URLs externas (geradores de PDF, webhooks, importadores de imagem) podem se tornar vetores de ataque para SSRF.
( ) Qualquer funcionalidade que, por design, precise acessar uma URL fornecida pelo usuário é um vetor de SSRF em potencial.
( ) Bypass de filtros pode ser feito usando representações alternativas de IP, como `127.0.0.1`, `0.0.0.0` ou `[::1]`.

4. Discorra sobre *webhooks* e correlacione com SSRF.

5. O que são IAM roles? Pode ser utilizado para roubar dados com SSRF?

6. Qual endpoint é considerado o alvo clássico de metadata em ambientes AWS?

   A. `/meta/v1/credentials`

   B. `/latest/meta-data/iam/security-credentials/`

   C. `/api/internal/tokens`

   D. `/computeMetadata/v1/`

7. Cite **duas técnicas de bypass** de filtros de SSRF e explique brevemente cada uma.

8. Liste **três mitigações** recomendadas para prevenir SSRF.

9. Correlacione as colunas

1. Transferência de arquivos e bypass de firewall	( )	gopher
2. Acesso a dicionários e info gathering	( )	ftp
3. Comunicação com serviços internos	( )	dict
4. Leitura de arquivos locais	( )	file

10. **SSRF vs. CSRF vs. IDOR** Preencha a tabela abaixo diferenciando as três vulnerabilidades:

Critério	**SSRF**	**CSRF**	**IDOR**
Quem faz a requisição			
Quem é enganado			
Alvo típico			
Exemplo prático			

11. **Defesa em profundidade** Para cada camada abaixo, cite uma mitigação específica contra SSRF:

Aplicação: _____

Rede: _____

Nuvem: _____

Monitoramento: _____